

Andariel

North Korean espionage that pays for itself — collection against defence and nuclear programmes, funded by ransomware run against healthcare, in some recorded cases against the same victim on the same day.

ATTRIBUTION	ACTIVE SINCE	OBJECTIVE	FUNDING
North Korea — RGB 3rd Bureau	2009	Collection	Ransomware against healthcare
ALSO TRACKED AS Onyx Sleet • Silent Chollima • Stonefly • APT45			

01 ASSESSMENT

The espionage pays for itself

Andariel is a North Korean state-sponsored group attributed to the Reconnaissance General Bureau's 3rd Bureau and assessed to be a subset of the Lazarus Group. ¹ Its collection requirements are stated unusually plainly: tanks and submarines, fighter aircraft and UAVs, missiles and missile defence, satellites, uranium processing and enrichment, shipbuilding, robotics and additive manufacturing. The material sought is contract specifications, bills of materials, design drawings and engineering documents. ²

Tradecraft has shifted. The group historically led with spear-phishing; since around 2023 it has mostly exploited n-day vulnerabilities in public-facing web servers, followed by web shells. Post-access tooling is a large custom RAT family — `TigerRAT`, `SmallTiger`, `Dora RAT` among others — packed with commercial protectors, alongside commodity tooling including `Sliver`, `Ngrok` and `Mimikatz`. ³

Key judgment. Most state-sponsored collection is a cost centre; this one is not. The group runs ransomware against healthcare entities and uses the proceeds to fund the espionage — so a single victim can be hit by two operations that look like completely different actors, in some recorded cases on the same day. ²

02 CHRONOLOGY

From watering holes to self-funded collection

2009



Earliest tracked activity against South Korean targets

Operations against government, military and financial targets used watering-hole attacks carrying zero-day exploits, spear-phishing and ActiveX exploitation, and hid payload code inside PNG and BMP images. ¹

2021-05



Maui ransomware deployed against healthcare

Servers responsible for diagnostics, electronic health records and imaging were encrypted at US healthcare organisations. The proceeds funded intelligence collection, making these victims a revenue source rather than a collection target. ⁴

2023



N-day exploitation replaces phishing as the way in

Microsoft records the group mostly exploiting known vulnerabilities in internet-facing software — Log4j, Confluence, PaperCut, TeamCity, Apache ActiveMQ — with public and custom exploits, rather than leading with spear-phishing. ³

2023-12



1.2 TB taken from South Korean defence contractors

The largest single collection volume attributed to the group in reviewed reporting — the collection mandate realised at scale. ³

03 CONCLUSION

What this means for a defender

01

Healthcare faces this actor without holding any collection-relevant data. The threat there is the funding arm — ransomware chosen for payout, not for secrets.

02

The controllable exposure is patch latency on public-facing software. The recorded way in since 2023 is known vulnerabilities in Log4j-, Confluence- and TeamCity-class products, not novel phishing.

03

Collection tradecraft watches engineers work — keylogging and screen recording — so controls scoped only to document stores miss the channel the actor prefers.

04 RISK & IMPACT

Sector exposure

Defence and aerospace

 **CRITICAL**

The stated collection requirement: tanks, submarines, torpedoes, fighter aircraft, UAVs, missiles and satellites are named individually.

Engineering and manufacturing

 **HIGH**

Shipbuilding, marine engineering, robotics and additive manufacturing are named requirements, and 2024 activity reached South Korean manufacturers directly.

Healthcare

 **HIGH**

Exposed as a ransomware revenue source rather than a collection target — a different threat from the same actor, and the reason the espionage is funded at all.

Education and research

 **MODERATE**

South Korean educational institutions were hit in 2024, and research institutes sit adjacent to the nuclear and engineering requirements.

Retail and hospitality



MINIMAL

No indication of interest: neither the technical information the requirements name nor the ransomware payout profile of healthcare.

Sector risk is an analyst judgment on a five-level scale — critical, high, moderate, low, minimal. It is a different kind of claim from a CVSS score and is never expressed as a number.

05 ATTACK FLOW

How an intrusion runs

01



INITIAL ACCESS

The way in is unpatched, public-facing software

T1190

Exploit Public-Facing Application — n-day vulnerabilities in internet-facing servers, using public and custom exploits. Log4Shell is the named example; Confluence, PaperCut, TeamCity and Apache ActiveMQ are also recorded.

T1566.001

Spearphishing Attachment — the group's earlier lead technique, retained rather than retired.

02



PERSISTENCE

Web shells hold the foothold

T1505.003

Web Shell — planted on the exploited servers to keep access independent of the exploit that opened it, and to reach the applications and data behind them.

The objective: engineering data, by file and by screen

T1005

Data from Local System — 1.2 TB taken from South Korean defence contractors in December 2023.

T1056.001

Keylogging — **TigerRAT** logs keystrokes: watching an operator work rather than harvesting logons.

T1113

Screen Capture — for a mandate built around drawings and design documents, **TigerRAT** screen recording returns material a file grab would miss.

The funding arm: ransomware against healthcare

T1486

Data Encrypted for Impact — **Maui** ransomware run against US healthcare, encrypting diagnostics, health-record and imaging servers. The proceeds pay for the collection operations against everyone else.

A custom RAT family plus commodity tooling

TigerRAT

Custom backdoor providing keylogging and screen recording.

BACKDOOR

Dora RAT

Go backdoor used against education, construction and manufacturing.

BACKDOOR

Maui

Ransomware run against healthcare to fund the espionage operations.

RANSOMWARE

Sliver **C2**

Open-source framework used for implants against defence and aerospace.

COMMODITY

Mimikatz S0002

Credential dumping; reporting names the tool without the store read.

COMMODITY

Ngrok

Tunnelling utility for outbound operator channels.

COMMODITY

SOURCES

- 1 MITRE ATT&CK — Andariel, G0138
- 2 Joint advisory AA24-207A — FBI, CNMF, CISA, DC3, NSA, ROK NIS/NPA, UK NCSC, July 2024
- 3 Microsoft — Onyx Sleet uses array of malware to gather intelligence for North Korea, July 2024
- 4 Joint advisory AA22-187A — Maui ransomware, July 2022

Specimen page: one visual system carrying both the written analysis and the ATT&CK flow. Accent pair tuned to the subject objective (espionage/collection).